12/10/26

Case Study - II

Securing the University Examination System

A university uses an Operating System based examination management system to store student records, examination marks, faculty details & question papers. The system has three main user groups: Students, Faculty, & Administrators. Students should be able to view only their own marks & download permitted learning materials. Faculty members need to view student records and enter or modify marks. Administrators manage user accounts, permissions & system configuration

The university has assigned permissions through roles, but an audit review identifies the following events:

- At 10:00, the account student07 has three failed attempts.
- At 10:03, the student07 successfully logs in.
- At 10:04, student07 attempts to open ExamMarks.xlsx, which contains marks for an entire class.
- At 10:05, the system records an attempted modification of ExamMarks.xlsx by student07.
- At 10:15, Faculty02 modifies marks in ExamMarks.xlsx & saves the file successfully.
- At 10:20, an administrator discovers that former faculty member's account is still active
- The audit log is stored on the same server, and users with broad permissions may be able to modify or delete it.

unit 1

based on security audits & logs

Page No.
Date

The university wants to protect confidentiality, integrity & availability; prevent unauthorised access; maintain accountability; and investigate suspicious activity. You are asked to recommend appropriate operating system access control, security administration & auditing measures.

Questions

Q1. Identify the main security problems in the case study. (4 marks)
list at least four risks or weaknesses indicated by the scenario

Q2. Explain the difference between authentication & authorisation using student 07 as an example (4 marks).
distinguish identity verification from permission checking.

Q3. Recommend an access control policy for students, Faculty, & Administrators. Justify your choice (5 marks).
Consider how permissions should be assigned & managed

Q4. Prepare a suitable Access Control list (ACL) for ExamMarks.xlsx
Specify appropriate Read, Write, & Delete permissions for each (5 marks) user group.

Q5. Explain how the principle of least Priviledge should be applied in this system. (4 marks).
state what each group needs to do and which unnecessary permissions should be removed.

Q6. Interpret the audit events from 10:00 to 10:05. what should the security Team do next? (5 marks).
Explain why the sequence is suspicious without assuming that it proves an attack.

Page No.
Date

Q7 Identify at least five events that should be recorded in the audit logs (3 marks).
Include login, file/account, permission, and/or administrative events

Q8. Explain why the audit logs must be protected and recommend two ways to protect them. (3 marks).
Consider unauthorised modification, deletion, and investigation.

Q9. What action should be taken regarding the former faculty member's active account? Explain. (3 marks).
Relate your answer to account management & access removal.

Q10. suggest a practical incident - response & corrective - action plan for the university (4 marks).
Include investigation, access review, policy changes & follow up monitoring

Page No.
Date

Answers.

Ans1: The main security problems in the university access control system are:

a. Weak Authentication: The system may not properly verify the identity of users before granting access.

b. Excessive Permissions: Students faculty, administrators may have unnecessary access to sensitive data and resources.

c. Unauthorized Access: Students may access confidential information or resources without permissions.

d. Lack of Auditing & Monitoring: Activities may go unnoticed if access logs are not properly monitored or reviewed.

Ans2 Authentication is the process of verifying the identity of a user.

Example: Student 07 uses a username and password to log in to the university system. The system verifies the credentials to confirm the student's identity

Authorisation is the process of determining what an authenticated user is allowed to access or do.

Example: After logging in, student 07 can view personal academic records and course materials but cannot access faculty records or modify examination marks.

Ans 3 The university should apply Role Based Access Control (RBAC), in which permissions are assigned according to the user's role.

1. students: Can view their own academic records, access course materials & submit assignments.

2. Faculty: Can upload course materials manage assignments, and enter or update marks for their assigned courses.

3. Administrators: Can manage user accounts, assign roles, configure security settings & monitor system activities.

Role Based Access Control simplifies permission management, prevents unauthorised access, reduces security risks & ensures that users can access only the resources required for their roles.

Ans 4. The following ACL (Access Control List) are:

| User | Read | Write | Delete. |
|---|---|---|---|
| Students | Yes (own results only) | No | No |
| Faculty | Yes (assigned courses only) | Yes (assigned courses only) | No |
| Administrators | Yes. | Yes (authorised changes only) | Yes (w/ approv |

This Access control list protects the confidentiality and integrity of examination results.

Page No.
Date

Ans5. The Principle of least Privilledge (PoLP) states that every user should receive only the minimum permissions necessary to perform their duties.

It should be applied as follows:

i. students: Receives permissions to view their own results & access learning materials, without permission to modify examination records.

ii. Faculty: Receive access only to the courses & student records they are responsible for.

iii. Administrators: Receive only the administrative privilledges required for their duties.

The Principle reduces unauthorised access, accidental changes, & potential security threats.

PoLP reduces the risk of unauthorised access, prevents accidental or malicious modification of examination records, also ensures every user has the only access required to perform their duties.

Ans6. The user tries to attempt 3 failed login attempts at 10:00, at 10:03 by successfully loging in, 10:04 student 07 attempts to access ExamMarks.xlsx, which contains the entire class's marks. At 10:05 attempt to modify the exam file.

The security team taks the following actions:

- Verify the account: check whether the login was legitimate or not.
- Block unauthorised access: by enforcing proper access permissions.
- Check file integrity: to confirm whether any marks were changed.
- Secure audit logs: by storing them seperately with restricted access to prevent tampering.

The security team should investigate the suspicious activity prevent unauthorised access, and protect examination records from modification.

Ans: The following events should be recorded in audit logs:

i. Login & Logout events: Records when the users log in & log out of the university system.

ii. Failed login attempts: Records unsuccessful login attempts to identify possible unauthorised access.

iii. Account management Events: Records the creation, modification, & deletion of user accounts.

iv. Permission changes: Records changes to user roles & access priviledges.

v. Administrative Activities: Records important actions performed by system administrators, such as changing system settings or accessing sensitive data.

Page No.
Date

Ans8. Audit logs must be protected because they contain important records of user activities & security events. unauthorised modification or deletion of these logs can hide suspicious activities & make investigations difficult.
Two ways of protecting audits logs:

- Restrict Access: Allow only authorised administrators to access audit logs and role based access controls.

- Prevent modification & deletion: Use tamper-resistant storage, encryption, and regular backups to protect logs from unauthorised changes or loss.

Ans9. The university should immediately disable the former faculty member's account & revoke their access to university systems. It should also terminate active sessions, review the account's previous activities, & remove any unnecessary permissions. This is important as former faculty members no longer require access to university resources.
Disabling inactive accounts reduces the risk of unauthorised access & data misuse.

Ans 10. Investigate: Reviewing audit logs, verify student 07's activities, & check whether any marks were changed without authorization.

Review access: Disable the former faculty's member account & examine the permissions of students, faculty & administrators

Page No.
Date

- Improve Security: Apply RBAC & the Principle of least Privilledge enforce strong passwords & and enable the multi-factor authentication where possible.

- Monitor regularly: Protect audit logs, review, suspicious activities, conduct periodic access reviews & verify that corrective measures are effective.

These steps will help protect confidential student records, prevent unauthorised changes & improve the overall the security of the university's operating system